

ACTIVITY PACK

Activity 4: Discussion Questions

Activity 4 - Evidence-Based Rogue Agent Incident Review

Course	AI Security for Autonomous AI Agents
Course code	TGS-2025060473
Version	3.0 20 August 2026

Tertiary Infotech Pte Ltd | UEN 20120096W

Discussion Questions

Activity 4 - Discussion Questions

Evidence-Based Rogue Agent Incident Review

Work through all five questions. Keep each fact tied to the case source and preserve the evidence label: CASE-V or CASE-R.

Q1 - Reconstruct a source-to-sink chain (K5)

Choose EchoLeak or the Amazon Q extension event. Map:

- untrusted source;
- mechanism;
- identity or permission used;
- privileged sink or action;
- observed or possible impact;
- earliest deterministic control;
- residual risk and required evidence.

Q2 - Separate capability, vulnerability, and impact (K5)

For all four cases, identify which statements describe a normal capability, which describe a vulnerability or control failure, and which describe an impact. Explain why code execution, network access, or persistent memory is not automatically a vulnerability.

Q3 - Distinguish evidence classes (K5)

Explain why:

- EchoLeak may be called a verified vulnerability without claiming every customer was attacked;
- the Amazon Q event must state that the malicious code did not execute;
- the Replit event must state that the data was restored and no data was lost;
- the ClawHavoc figures cannot be presented as today's marketplace prevalence.

Q4 - Break each chain at the earliest point (K5)

For every case, choose one preventive control and one detective or recovery control. State the owner, implementation point, test evidence, operational cost, and expected residual risk.

Q5 - Set your organisation's authority boundary (K5)

Classify these actions as **agent alone**, **human approval required**, or **prohibited**:

- read a non-sensitive repository;
- install or update a community skill;
- access a long-lived production token;
- send data to a new internet destination;
- write to production;
- delete a production resource;
- change access-control roles;
- create a scheduled background task.

For every action that requires approval, specify what the reviewer must see and why a system prompt saying "ask before acting" is not equivalent to a deterministic policy gate.